第 15 章 密钥管理和分发

0. 学习目标总览

教材给出本章五个学习目标：

1. 论述密钥分层的概念。
2. 了解利用非对称加密分发对称密钥的技术问题。
3. 概述公钥分发的各种方法及其风险。
4. 列举并解释X.509证书的元素。
5. 概述公钥基础设施的概念。

本章主线是为通信方建立“可信且当前有效的密钥”：

```
密钥管理
  |
  |-- 对称密钥分发
  |     |-- 主密钥保护会话密钥
  |     |-- KTC / KDC
  |     `-- 分层与短生命期
  |
  |-- 公钥参与分发
  |     |-- 公钥加密短会话密钥
  |     `-- 认证公钥归属，防止中间人攻击
  |
  |-- 公钥可信分发
  |     |-- 公开发布 / 公开目录 / 公钥授权
  |     `-- 公钥证书
  |
  `-- X.509 与 PKI
        |-- 证书字段、证书链、撤销、扩展
        `-- CA、RA、存储库、终端实体、信赖方
```

密钥管理包括密钥的生成、创建、保护、存储、交换、替换和使用，也包括访问限制以及对每个密钥访问、用途和上下文的监视与记录。密码系统的安全性不仅取决于算法，也取决于密钥管理是否成功。

1. 学习目标 1：密钥分层的概念

1.1 对称密钥分发的四种方式

对称加密要求通信双方持有同一秘密密钥。为限制攻击者可用于密码分析的数据量，还需要频繁更换密钥。教材归纳了 A、B 之间的四种分发方式：

1. A 选择密钥，以物理方式交给 B。
2. 第三方选择密钥，以物理方式交给 A 和 B。
3. 若 A、B 已共享旧密钥，由一方用旧密钥加密新密钥后发送给另一方。
4. 若 A、B 分别与第三方 C 建有加密连接，由 C 经这些连接把密钥传给双方。

前两种人工方式可用于只有相邻设备通信的链接加密，却难以支持大规模端到端加密。若 n 台主机之间任意两台都可能通信，所需成对密钥数量为

$$\frac{n(n-1)}{2}$$

例如，1000 个节点约需 50 万个密钥；若应用层有 10000 个相互通信的用户或进程，则约需 5000 万个密钥。

第 3 种方式可减少人工分发，但旧密钥一旦泄露，攻击者便可解开后续新密钥，形成连续泄露。大规模端到端加密通常采用第 4 种方式，由密钥分发中心为每个用户动态提供密钥；每个用户只需与中心共享一个唯一的长期密钥。

1.2 主密钥、会话密钥与临时密钥

密钥	生命期与用途	安全意义
主密钥	通信实体与可信第三方长期共享，用来保护会话密钥的传递。	使用频率低，但泄露会影响其保护的多个下层密钥。
会话密钥	在一次逻辑连接期间供两个通信实体使用，如一次 TCP 连接。	会话结束后丢弃，限制单个密钥泄露的影响范围。
临时密钥	只使用一次或生命期极短。	进一步缩小密钥暴露窗口和受保护数据量。

1.3 KTC 与 KDC

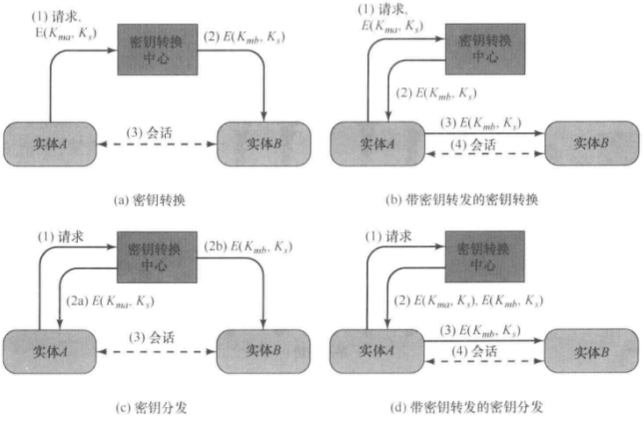


图 15.1　两个通信实体之间的密钥分发

图 15.1 两个通信实体之间的密钥分发

设会话密钥为 K_s，A、B 与可信第三方共享的主密钥分别为 K_{ma}、K_{mb}。

第三方	谁产生 K_s	分发过程
密钥转换中心（KTC）	A 等通信实体自行生成或取得。	A 用 K_{ma} 加密 K_s 交给 KTC；KTC 解密，再用 K_{mb} 重新加密，直接交给 B 或经 A 转发。
密钥分发中心（KDC）	KDC 生成。	KDC 分别用 K_{ma}、K_{mb} 加密 K_s，直接交给双方，或将两个密文都交给 A，由 A 转发 B 的部分。

实际协议还必须认证参与方，并常用时间戳限制密钥交换发生的时间或所分发密钥的生命期。

1.4 密钥层次

许多协议先用层次较高的密钥保护新建的层次较低密钥，再由低层密钥直接保护通信：

```
高层密钥
  |-- 使用较少、更换较慢
  |-- 需要更强的抗密码分析能力
  `-- 加密并分发下层密钥
        |
        `-- 低层密钥
            |-- 使用较频繁、更换较频繁
            |-- 直接保护通信
            `-- 可进一步派生或保护临时密钥
```

低层密钥接触更多数据，因此频繁更换可限制密码分析材料和泄露影响。高层密钥虽然使用较少，但一旦泄露会连带破坏多个下层密钥，因而必须得到更强保护。

2. 学习目标 2：利用非对称加密分发对称密钥

公钥运算效率较低，通常不直接加密大数据块，而用于保护较短的对称会话密钥。通信双方获得会话密钥后，再用高效的对称算法保护实际数据。

2.1 简单的密钥分发方案

若 A 要与 B 通信：

1. A 临时生成公私钥对 $\{\mathrm{PU}_a, \mathrm{PR}_a\}$，向 B 发送 $\mathrm{PU}_a \parallel \mathrm{ID}_A$。
2. B 生成会话密钥 K_s，发送 $E(\mathrm{PU}_a, K_s)$。
3. A 使用私钥恢复会话密钥：

$$D(\mathrm{PR}_a, E(\mathrm{PU}_a, K_s)) = K_s$$

通信结束后双方丢弃 K_s。该方案在会话前后都不需要保存会话密钥，可以抵抗单纯窃听，但没有认证 A 最初发送的公钥。

2.2 中间人攻击

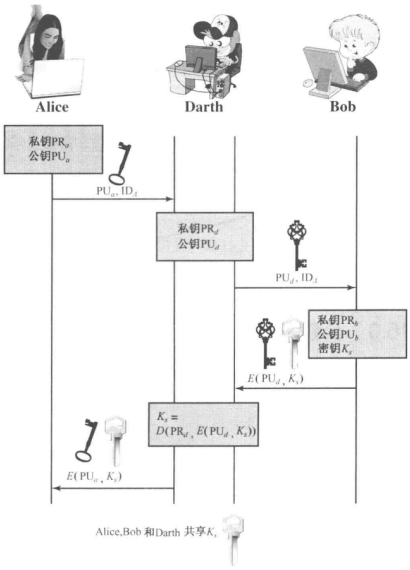


图 15.4　中间人攻击

图 15.4 中间人攻击

若敌手 D 控制信道，可将 A 的公钥替换成自己的公钥：

1. A 发送 $\mathrm{PU}_a \parallel \mathrm{ID}_A$。
2. D 截获后改发 $\mathrm{PU}_d \parallel \mathrm{ID}_A$。
3. B 生成 K_s，发送 $E(\mathrm{PU}_d, K_s)$。
4. D 用 PR_d 解密并取得 K_s。
5. D 再向 A 发送 $E(\mathrm{PU}_a, K_s)$。

A、B 最终得到同一个 K_s，却不知道 D 也持有它。此后 D 只需被动窃听就能解密通信。关键结论是：**使用公钥加密并不自动认证公钥的所有者**；公钥归属若不可信，协议不能抵抗主动替换。

2.3 同时保证保密性和认证

假设 A、B 已可靠获得彼此当前公钥，可先用时变值完成双向认证，再传送会话密钥：

1. A 用 B 的公钥加密 ID_A 和时变值 N_1。
2. B 用 A 的公钥加密返回 N_1 和新时变值 N_2；返回 N_1 表明 B 能解开第 1 条消息。
3. A 用 B 的公钥加密返回 N_2；B 据此认证 A。
4. A 选择 K_s，先用自己的私钥处理，再用 B 的公钥加密：

$$M = E(\mathrm{PU}_b, E(\mathrm{PR}_a, K_s))$$

5. B 依次使用自己的私钥和 A 的公钥恢复：

$$D(\mathrm{PU}_a, D(\mathrm{PR}_b, M)) = K_s$$

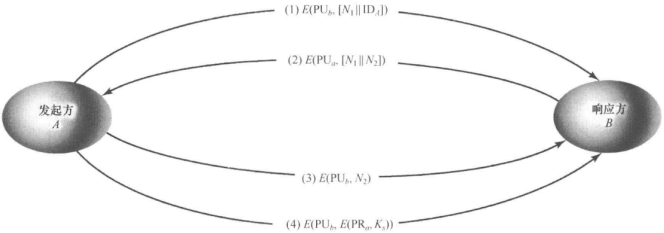


图 15.5　秘密密钥的公钥分发

图 15.5 兼具保密性和认证的会话密钥分发

外层公钥加密使只有 B 能读取密钥，内层私钥运算使 B 能确认密钥来自 A；N_1、N_2 则把响应绑定到当前交互。

3. 学习目标 3：公钥分发方法及其风险

公钥可以公开，但接收者仍须确认两个问题：公钥确实属于所声称的主体，并且它仍是当前有效的公钥。教材将分发方法分为四类。

方法	基本做法	主要风险或代价
公开发布	用户直接发送或广播自己的公钥。	任何人都可冒名发布伪造公钥；真正用户发现前，攻击者可读取加密消息或伪造认证。
公开可访问的目录	可信管理员维护动态的 {名称, 公钥} 目录；注册、更新和目录响应须经安全认证。	管理员私钥泄露或目录记录被篡改时，攻击者可假冒任意用户。
公钥授权	用户每次向在线管理员请求当前公钥，管理员对公钥、原请求和时间戳签名。	每次取钥都依赖管理员，消息较多，管理员可能成为瓶颈；缓存还需周期更新。
公钥证书	CA 把主体标识、公钥和时效信息组成数据块并签名，证书可由任何渠道传递。	验证者必须可靠获得 CA 公钥，并检查证书有效期和撤销状态。

3.1 公开目录与公钥授权

公开目录中的每个条目包含名称和公钥。用户必须亲自或通过安全认证通信注册、替换公钥；管理员向用户提供目录信息的通信也必须受认证保护。

公钥授权进一步控制取钥过程。A 请求 B 的公钥时携带时间戳，管理员签名的响应包含：

- B 的当前公钥 PU_b；
- A 的原始请求，用于发现请求被替换；
- 原始时间戳，用于排除包含旧公钥的重放响应。

A、B 取得公钥后，还用 N_1、N_2 确认对方能解开相应公钥加密的消息。完整过程需要 7 条消息。双方可缓存已经验证的公钥，但必须周期性刷新；否则缓存本身会使旧公钥继续被使用。

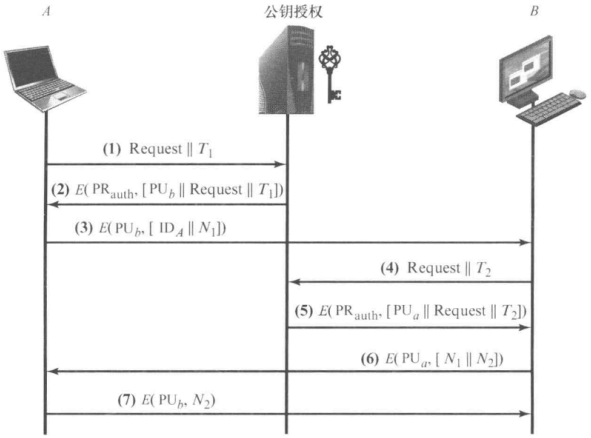


图 15.8　公钥分发方案

图 15.8 在线公钥授权的 7 条消息

图中第 1、2 条消息使 A 得到 B 的当前公钥，第 4、5 条消息使 B 得到 A 的当前公钥；第 3、6、7 条消息用 N_1、N_2 完成双方确认。管理员签名解决公钥来源和时效问题，时变值解决本次交互的时效问题，两类机制承担的职责不同。

3.2 公钥证书

证书将公钥、所有者标识及相关信息组成数据块，由可信第三方签名。用户通过安全、认证的方式把公钥交给证书管理员，取得证书后可公开传递。证书机制应满足：

1. 任何通信方都能读取证书，确定所有者名称和公钥。
2. 任何通信方都能验证证书来自证书管理员而非伪造者。
3. 只有证书管理员能够生成和更新证书。
4. 任何通信方都能验证证书的时效性。

教材给出的简化证书形式为

$$C_A = E(\mathrm{PR}_{\mathrm{auth}}, [T \| \mathrm{ID}_A \| \mathrm{PU}_a])$$

验证者使用管理员公钥读取并验证：

$$\begin{aligned} D(\mathrm{PU}_{\mathrm{auth}}, C_A) &= D(\mathrm{PU}_{\mathrm{auth}}, E(\mathrm{PR}_{\mathrm{auth}}, [T \| \mathrm{ID}_A \| \mathrm{PU}_a])) \\ &= T \| \mathrm{ID}_A \| \mathrm{PU}_a \end{aligned}$$

时间戳 T 相当于截止日期。若 A 的旧私钥泄露并已换钥，旧证书若仍被重放，接收方可能继续用泄露公钥加密；时效检查可限制这种风险。

4. 学习目标 4：X.509 证书的元素

X.509 是 X.500 目录服务体系的一部分，定义公钥证书结构和基于证书的认证框架。每张证书包含主体公钥，并由可信证书颁发机构（CA）用私钥签名。标准不限定必须使用哪一种数字签名算法或哈希函数。

目录服务器只负责存取证书，不生成密钥或签发证书。证书由 CA 签名，攻击者无法在不被发现的情况下修改，因此目录无需为了防止证书伪造而受到特别保护。

4.1 证书字段

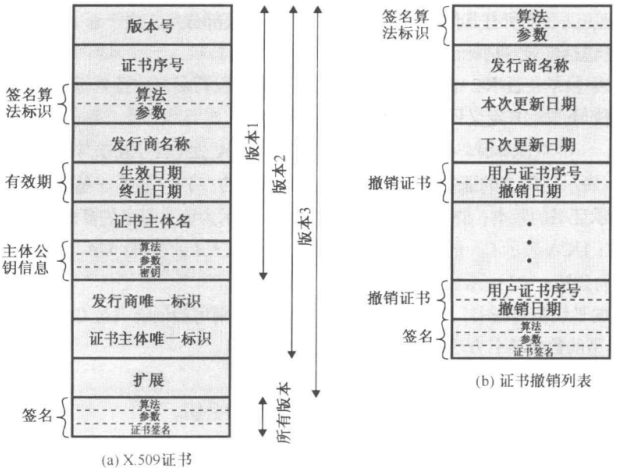


图 15.11 X.509 格式

图 15.11 X.509 证书与证书撤销表的格式

字段	含义
版本号	区分证书格式。默认是版本 1；出现发行商或主体唯一标识时为版本 2；出现扩展时为版本 3。
证书序号	在同一 CA 内唯一标识证书的整数。
签名算法标识	CA 为证书签名所用的算法及参数。
发行商名称	创建并签署证书的 CA 名称。
有效期	证书生效日期和终止日期。
证书主体名	证书属主名称；持有对应私钥的主体是证书中公钥的所有者。
主体公钥信息	主体公钥、算法标识符和相关参数。
发行商唯一标识	可选位串，在名称复用时唯一标识 CA。
证书主体唯一标识	可选位串，在名称复用时唯一标识主体。
扩展	版本 3 加入的一个或多个可选扩展字段。
签名	覆盖证书所有其他字段的 CA 数字签名，并包含签名算法标识。

唯一标识字段在版本 2 中加入，但实际较少使用。X.509 用

$$Y\langle\langle X\rangle\rangle$$

表示“CA Y 为主体 X 签发的证书”。若用户可靠掌握 Y 的公钥，就能验证 $Y\langle\langle X\rangle\rangle$，并取得 X 的可信公钥。

4.2 证书链与 CA 层次

用户很多时，不能要求所有人都从同一个 CA 获得证书。每个用户只需安全掌握一个受信 CA 的公钥，再沿 CA 间的证书逐级取得其他主体的公钥。

若 A 信任 X_1，而 B 的证书由 X_2 签发，A 可使用证书链

$$X_1\langle\langle X_2\rangle\rangle\ X_2\langle\langle B\rangle\rangle$$

验证过程为：

1. 用 X_1 的公钥验证 $X_1\langle\langle X_2\rangle\rangle$，取得可信的 X_2 公钥。
2. 用 X_2 的公钥验证 $X_2\langle\langle B\rangle\rangle$，取得可信的 B 公钥。

一般长度为 N 的链为

$$X_1\langle\langle X_2\rangle\rangle\ X_2\langle\langle X_3\rangle\rangle\ \cdots\ X_N\langle\langle B\rangle\rangle$$

链中每一张证书都由上一阶段已经验证的公钥检查。X.509 建议把 CA 按层次组织，以便寻找证书路径。每个 CA 的目录项包含：

- **前向证书**：其他 CA 为本 CA 签发的证书；
- **后向证书**：本 CA 为其他 CA 签发的证书。

4.3 证书撤销与 CRL

证书可能因以下原因在到期前撤销：

1. 用户私钥被认为已经不安全。
2. 用户不再信任 CA，例如主体名改变、证书废弃或证书未按 CA 规则签发。
3. CA 证书被认为已经不安全。

每个 CA 都必须维护由其签发、尚未到期但已经撤销的证书撤销表（CRL）。CRL 由发行 CA 签名，包含发行商名称、本次更新时间、下次更新时间，以及每张撤销证书的序号和撤销时间。

证书序号在同一 CA 内唯一，因此足以标识被撤销证书。收到证书后，用户不仅要验证 CA 签名和有效期，还必须检查撤销状态。可本地缓存证书和 CRL 以减少目录访问开销，但缓存必须及时更新。

4.4 X.509 版本 3 扩展

版本 2 难以表示互联网邮件地址、URL、安全策略、公钥用途范围以及用户和 CA 的密钥更新信息。版本 3 因此加入可选扩展。每个扩展包含：

1. 扩展标识；
2. 危险指示；
3. 扩展值。

若危险指示为 `TRUE`，而实现不能识别或处理该扩展，则必须把证书视为非法。

扩展类别	主要字段与作用
密钥和策略信息	授权密钥标识符区分同一 CA 的不同密钥；主体密钥标识符区分主体密钥；密钥使用限定签名、密钥加密、数据加密等用途；私钥使用期限定私钥生命期；证书策略和策略映射说明适用规则。
证书主体和发行商属性	主体可选名称和发行商可选名称支持邮件地址、URL 等名称形式；主体目录属性携带 X.500 目录属性。
证书路径约束	基本限制指出主体能否作为 CA 并可限制路径长度；名称限制约束后续主体名称空间；策略限制约束路径中的策略和策略映射。

5. 学习目标 5：公钥基础设施

5.1 PKI 的定义与要求

公钥基础设施（PKI）是一组用于管理证书和公私钥对的策略、流程、服务器平台、软件和工作站。其功能包括公钥证书的颁发、维护和撤销，主要目的在于让参与者安全、方便、有效地取得公钥。

PKI 架构应满足：

1. 参与者能读取证书，确定所有者名称和公钥。
2. 参与者能验证证书由 CA 签发且不是伪造的。
3. 只有 CA 能创建和更新证书。
4. 参与者能验证证书的时效性。

5.2 PKI 的基本组件

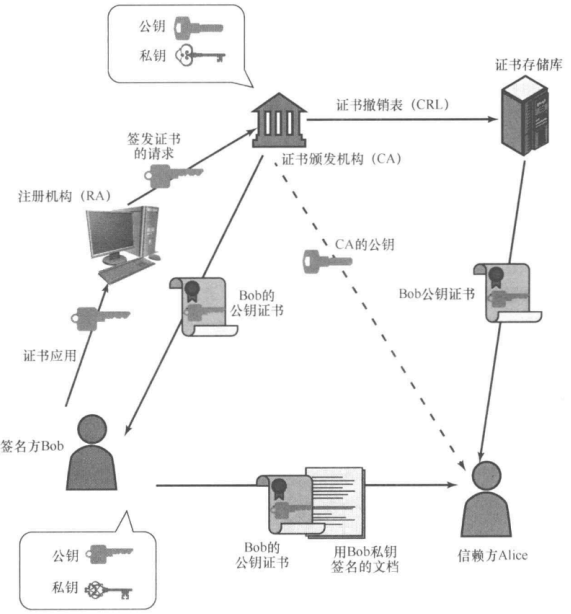


图 15.13　PKI 方案

图 15.13 PKI 方案

组件	职责
终端实体	在证书作用范围内被认证的用户、设备、程序或其他实体，也可作为 PKI 服务的使用者或提供者。
证书颁发机构（CA）	创建并分发证书，用签名把主体名称绑定到公钥；也可为主体生成密钥，并负责发布 CRL。
注册机构（RA）	可选组件，分担 CA 的管理工作，通常验证申请注册和取得证书的终端实体身份。
证书存储库	存储和检索证书、CRL 等信息，可采用 X.500/LDAP 目录，也可通过 FTP 或 HTTP 提供文件。
信赖方	依靠证书中的数据作出安全决策的用户或代理。

5.3 取得和使用公钥的流程

以信赖方 Alice 使用 Bob 的公钥为例：

1. Alice 先通过可靠、安全的方式取得 CA 公钥。
2. Alice 查询存储库，检查 Bob 的证书是否已经撤销。
3. 若未撤销，Alice 从存储库或 Bob 处取得证书。
4. Alice 用 CA 公钥验证证书签名、有效期和相关状态。
5. Alice 从通过验证的证书中取得 Bob 的公钥。
6. Alice 可用该公钥加密发给 Bob 的数据。
7. 若 Bob 用私钥签署文档，Alice 可用证书中的 Bob 公钥验证签名。

Bob 可以把证书附在签名文档中，也可假定 Alice 已拥有或能从存储库取得证书。无论传递渠道如何，Alice 都必须先验证证书，再信任其中的公钥。

企业可能使用多个 CA 和多个存储库。CA 可按层次组织，由广泛信任的根 CA 为从属 CA 签发证书。Web 浏览器、服务器、电子邮件客户端、智能手机等系统会预置根证书，使相应根 CA 成为证书验证路径的信任起点。

本章关键术语整理

术语	核心含义
密钥管理	管理密钥生成、保护、存储、交换、替换、使用、限制和审计的全过程。
密钥分发	在通信实体之间安全传递共享密钥或可信公钥的过程。
端到端加密	在通信端点之间保护数据，每个需要通信的主机、用户或进程对都要取得适当密钥。
主密钥	通信实体与可信第三方长期共享、用来保护会话密钥分发的密钥。
会话密钥	在一次逻辑连接期间使用并在结束后丢弃的临时共享密钥。
临时密钥	只使用一次或生命期极短的密钥。
KTC	转换并转交由通信实体生成或取得的会话密钥的可信第三方。
KDC	生成会话密钥，并用与通信实体共享的主密钥保护其分发的中心。
中间人攻击	攻击者替换公钥并转发消息，使通信双方在不知情时与其共享秘密。
公开目录	由可信管理员维护名称与当前公钥对应关系的动态目录。
公钥授权	在线管理员对当前公钥、原请求和时间戳签名后返回的分发方法。
公钥证书	由可信第三方签名、将主体标识与公钥及相关信息绑定的数据结构。
CA	创建和签署证书、维护证书状态并发布 CRL 的证书颁发机构。
证书链	从可信 CA 出发，逐级验证 CA 证书并最终验证主体证书的路径。
CRL	由 CA 签名发布、记录尚未到期但已经撤销证书的列表。
X.509	定义公钥证书结构和相关认证框架的标准。
PKI	通过策略、流程和技术组件管理证书与公私钥对的基础设施。
RA	在 PKI 中承担身份核验等注册管理工作的可选机构。
证书存储库	存储并提供证书、CRL 等 PKI 信息的系统。
信赖方	根据证书数据和验证结果作出安全决策的用户或代理。
根 CA	作为证书验证路径信任起点、为下级 CA 签发证书的 CA。

学习目标自检

1. 能否说明对称密钥分发的四种基本方式，并用 $n(n-1)/2$ 解释端到端成对密钥的规模问题？
2. 能否区分主密钥、会话密钥和临时密钥，并说明高层与低层密钥在使用频率、更新频率和保护强度上的差异？
3. 能否区分 KTC 与 KDC，并说明二者分别由谁产生会话密钥？
4. 能否写出简单公钥会话密钥分发的恢复公式，并解释它为什么只能抵抗窃听、不能抵抗中间人攻击？
5. 能否说明时变值、接收方公钥和发送方私钥在兼具保密性与认证的密钥分发方案中分别起什么作用？
6. 能否比较公开发布、公开目录、公钥授权和公钥证书四种方法的信任依据、风险与代价？
7. 能否列举并解释 X.509 证书的全部字段，并说明版本 1、2、3 与可选字段的关系？
8. 能否按顺序解释证书链的验证过程，并说明前向证书与后向证书的区别？
9. 能否列出证书提前撤销的原因，并说明 CRL 的签名、更新时间、证书序号和撤销时间分别有什么作用？
10. 能否概括 X.509 版本 3 的三类扩展，并解释危险指示、密钥使用和基本限制字段？
11. 能否列出 PKI 的五类基本组件，并用 Alice 获取 Bob 公钥的过程说明它们如何配合？
12. 能否说明根 CA、从属 CA、预置根证书和证书验证路径之间的关系？